

API SECURITY RISK ANALYSIS REPORT

{ API }

Read-Only API Security Assessment
of ReqRes Demo API



ANALYST

Shaik Sami Hassan

Cyber Security Intern / Security Analyst



INTERNSHIP PROGRAM

Future Interns

Cyber Security Internship – Task 3



ASSESSMENT TYPE

Read-Only API Security Risk Analysis



TARGET API

ReqRes Demo API

Base URL: <https://reqres.in>



TOOLS USED

Postman, Manual Analysis
and Security Documentation



ASSESSMENT DATE

May 19, 2025



AUTHENTICATION
ENFORCEMENT



SECURE
ACCESS



INPUT
VALIDATION



SECURITY
HEADERS



API Security Risk Analysis Report

Prepared by: Shaik Sami Hassan

Role: Cyber Security Intern / Security Analyst

Project: Future Interns Cyber Security Internship — Task 3

Assessment Type: Read-Only API Security Risk Analysis

Assessment Date: May 15, 2026

1. Executive Summary

A professional read-only API security assessment was performed on the ReqRes demo API to evaluate authentication mechanisms, access control behavior, error handling, input validation, and security header implementation.

The objective of this assessment was to identify potential security risks, evaluate the effectiveness of existing security controls, and document findings using standard application security assessment methodology.

Based on the testing performed, the API demonstrated strong baseline security controls with no critical vulnerabilities identified during the engagement.

2. Scope of Assessment

Target API: ReqRes Demo API

Base URL: <https://reqres.in>

Assessment Environment: Public Demo API

Assessment Type: Read-Only Security Testing

Testing Restrictions

The following activities were intentionally excluded from this assessment:

- No exploitation attempts
 - No authentication bypass attempts
 - No flooding or denial-of-service testing
 - No brute force testing
 - No destructive testing
 - No modification of target data
-

3. Tools Used

Primary Testing Tool

Postman

Postman was used as the primary testing platform for:

- Endpoint testing
- Authentication validation
- Header inspection
- Response analysis
- Status code verification
- Evidence collection

Secondary Assessment Methods

Additional verification was performed using:

- Manual API analysis
 - Browser-based network inspection
 - Security documentation review
 - OWASP API Security reference mapping
-

4. Testing Methodology

The assessment followed a structured application security workflow:

- | | |
|---------------------------------|-------------------------------|
| 1. API reconnaissance | 6. Security header inspection |
| 2. Authentication testing | 7. Input validation testing |
| 3. Authorization review | 8. Endpoint discovery |
| 4. Object-level access analysis | 9. Evidence collection |
| 5. Error handling validation | 10. Risk classification |

5. Security Findings

Finding F-01 — Authentication Enforcement

Endpoint Tested:

GET /api/users?page=1

Observation

Unauthenticated requests were blocked by the API.

Response

401 Unauthorized

Risk Level

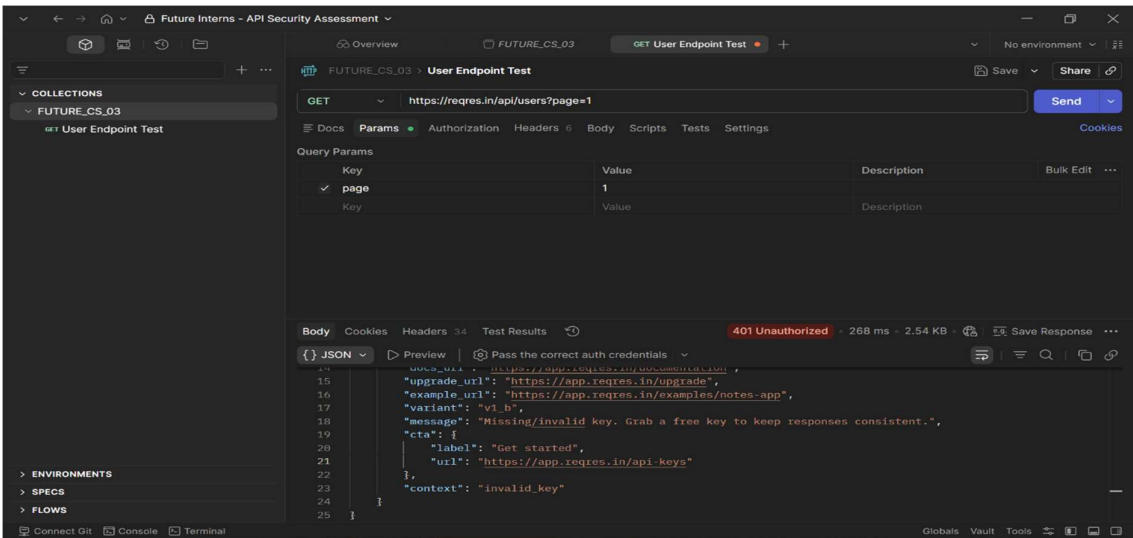
Low

Business Impact

Unauthorized users cannot directly access protected API resources.

Recommendation

Continue enforcing strong authentication controls across protected endpoints.



Finding F-02 — Authenticated Access Validation

Observation

Requests containing a valid API key successfully returned user data.

Returned Data Fields

- id
- email
- first_name
- last_name
- avatar

Risk Level

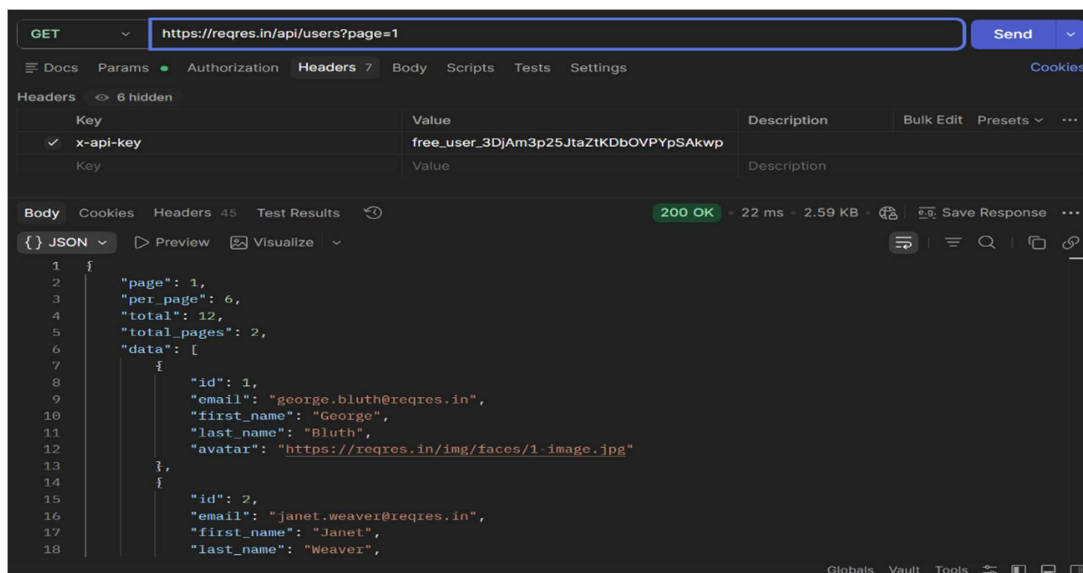
Low

Business Impact

Authentication mechanisms are functioning correctly and allow secure access for authorized users.

Recommendation

Continue using secure API credential management and validation controls.



Finding F-03 — Object-Level Access Review

Endpoint Tested:

GET /api/users/2

Observation

Direct object access was possible after authentication.

Risk Level

Informational

Business Impact

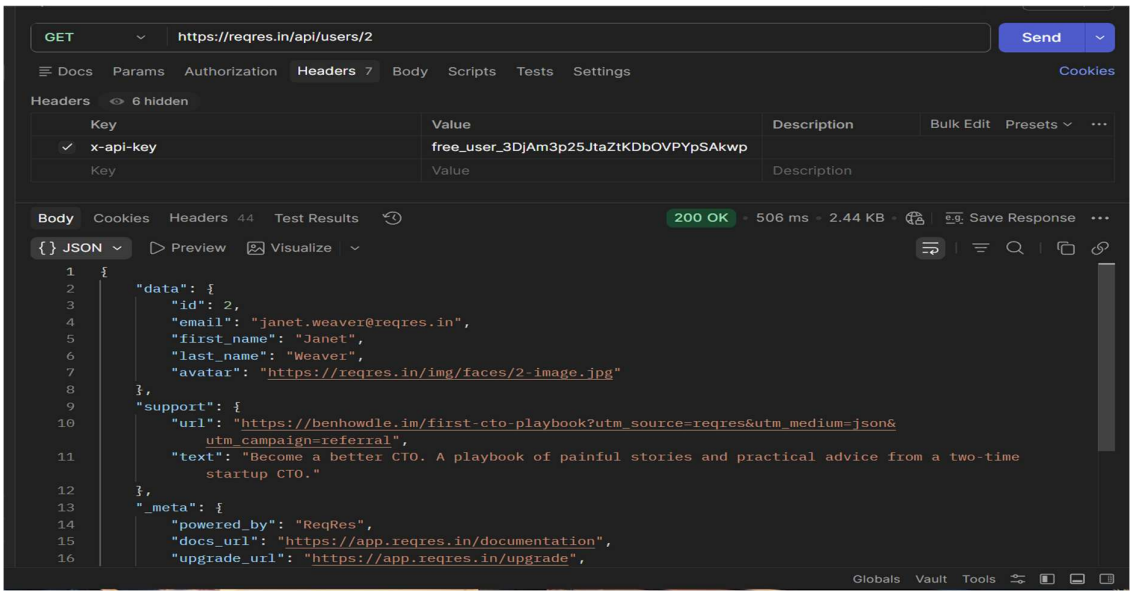
In production environments, improper object access controls could expose sensitive user records.

Recommendation

Apply object-level authorization where sensitive records exist.

Reference

OWASP API1 — Broken Object Level Authorization (BOLA)



Finding F-04 — Error Handling Review

Endpoint Tested:

GET /api/users/999

Observation

Invalid requests returned clean error responses without leaking internal application information.

Risk Level

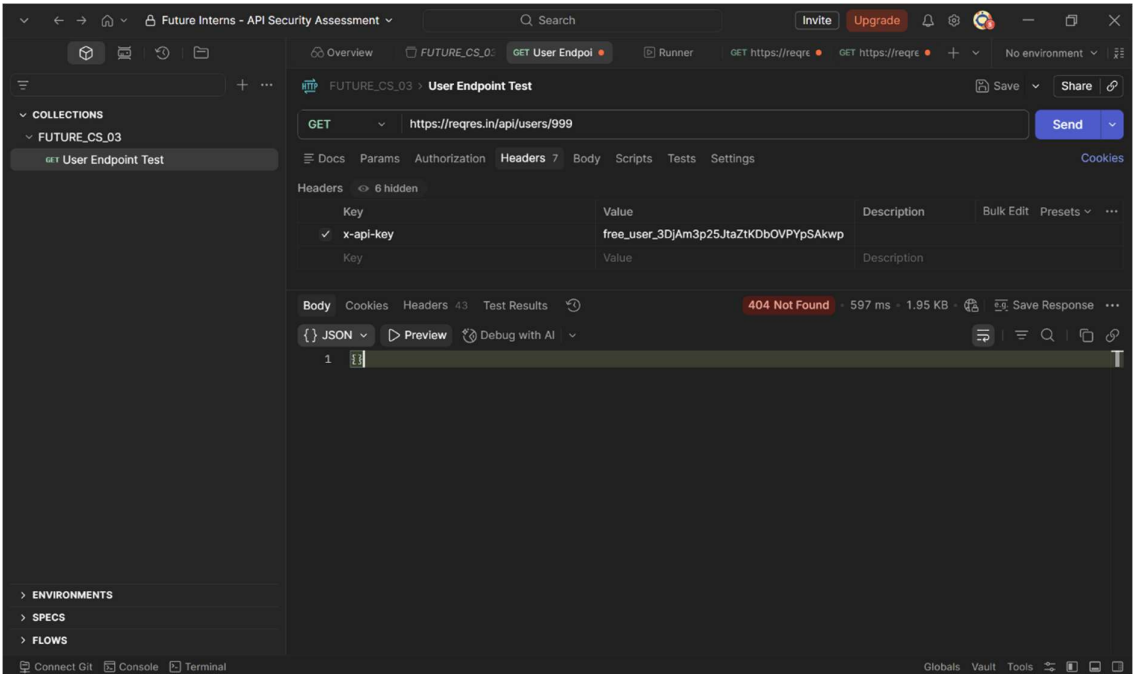
Low

Business Impact

Reduces information disclosure risks during reconnaissance.

Recommendation

Maintain secure error handling practices.



Finding F-05 — Security Header Review

Observation

Multiple security headers were observed including:

- Strict-Transport-Security
- X-Frame-Options
- X-Content-Type-Options
- Rate limiting headers
- Cloudflare protection headers

Risk Level

Low

Business Impact

Helps protect the API against browser attacks, insecure transport, and abuse attempts.

Recommendation

Maintain secure header policies and minimize unnecessary technology disclosure.

Body Cookies Headers 45 Test Results ↺		200 OK • 21 ms • 2.44 KB • 🏠 🌐 Save Response ⋮
Key	Value	
:status	200	
date	Thu, 14 May 2026 22:09:25 GMT	
content-type	application/json; charset=utf-8	
access-control-allow-origin	*	
cache-control	public, max-age=14400, s-maxage=60	ⓘ
cdn-cache-control	max-age=60	
cross-origin-opener-policy	same-origin	
cross-origin-resource-policy	same-origin	
etag	W/"308-APPL9XGtuWpWVioqllBYhlwgDYY"	
nel	{"report_to": "heroku-nel", "response_headers": ["Via"], "max_age": 3600, "s...	
origin-agent-cluster	?1	
ratelimit-limit	20	
ratelimit-policy	20;w=60	
ratelimit-remaining	19	
ratelimit-reset	60	
referrer-policy	strict-origin-when-cross-origin	
report-to	{"group": "heroku-nel", "endpoints": [{"url": "https://nel.heroku.com/report...	

Body	Cookies	Headers 45	Test Results	200 OK · 21 ms · 2.44 KB · Save Response ...
reporting-endpoints	heroku-nel="https://nel.heroku.com/reports?s=fU2lkek19dpXfRQ6qmtm...			
server	cloudflare			
strict-transport-security	max-age=31536000; includeSubDomains			
via	1.1 heroku-router			
x-content-type-options	nosniff			
x-dns-prefetch-control	off			
x-download-options	noopen			
x-frame-options	DENY			
x-permitted-cross-domain-policies	none			
x-powered-by	ReqRes.in - Deploy backends in 30 seconds			
x-ratelimit-limit	250			
x-ratelimit-remaining	249			
x-ratelimit-reset	249 03200			
x-reqres-docs	https://reqres.in			
x-reqres-message	This API is powered by ReqRes. Deploy your own backend in 30 secon...			
x-reqres-templates	https://app.reqres.in/templates			
x-reqres-tip	Need more than /api/users? Build custom collections - app.reqres.in/da...			
x-reqres-trial	true			

x-ratelimit-limit	250
x-ratelimit-remaining	249
x-ratelimit-reset	1778803200
x-reqres-docs	https://reqres.in
x-reqres-message	This API is powered by ReqRes. Deploy your own backend in 30 secon...
x-reqres-templates	https://app.reqres.in/templates
x-reqres-tip	Need more than /api/users? Build custom collections - app.reqres.in/da...
x-reqres-trial	true
x-reqres-trial-days-remaining	2
x-reqres-trial-expires	2026-05-16T14:04:14.369Z
x-reqres-upgrade	https://app.reqres.in/upgrade
x-request-id	a89725d7-a46c-7680-8178-e342b779e6cf
x-robots-tag	noindex, nofollow
x-xss-protection	0
age	28
cf-cache-status	HIT
content-encoding	br
cf-ray	9fbd3a2708d179ee-HYD

Finding F-06 — Input Validation Review

Endpoint Tested:

GET /api/users/abc

Observation

Invalid input values were handled safely by the API.

Response

404 Not Found

Risk Level

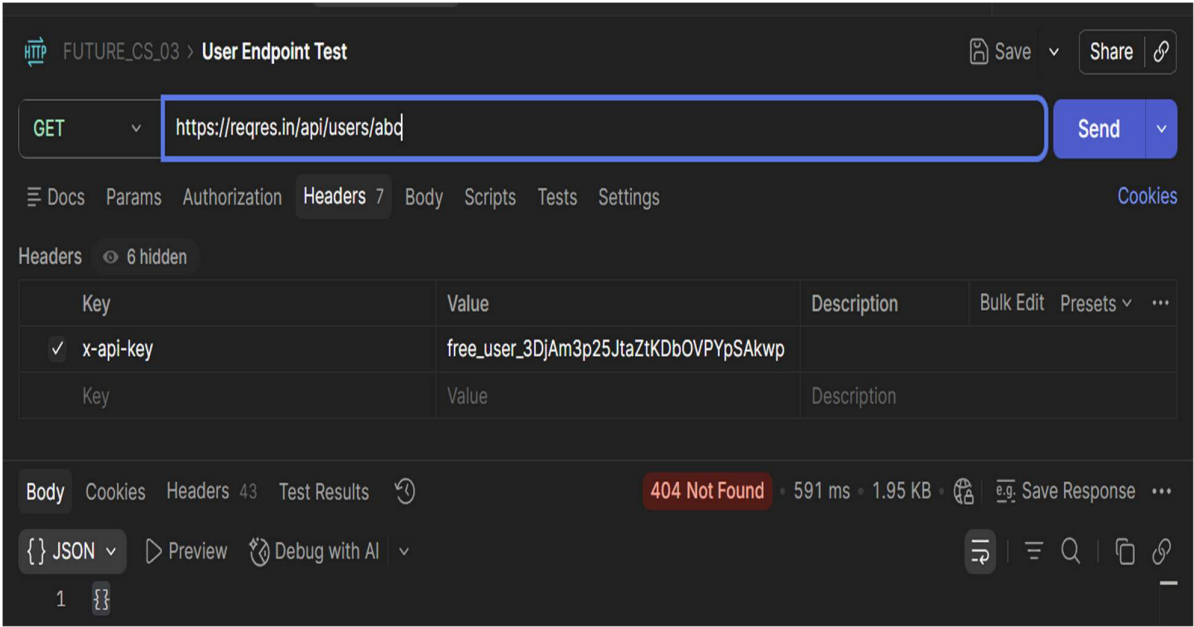
Low

Business Impact

Helps reduce backend exposure and prevents unnecessary information leakage.

Recommendation

Continue implementing strong input validation controls.



Finding F-07 — Endpoint Discovery Review

Observation

Public API endpoints were identified through official documentation review and manual endpoint enumeration during reconnaissance.

Identified Endpoints

- GET /api/users
- GET /api/users/{id}
- POST /api/login
- POST /api/register
- GET /api/unknown

Risk Level

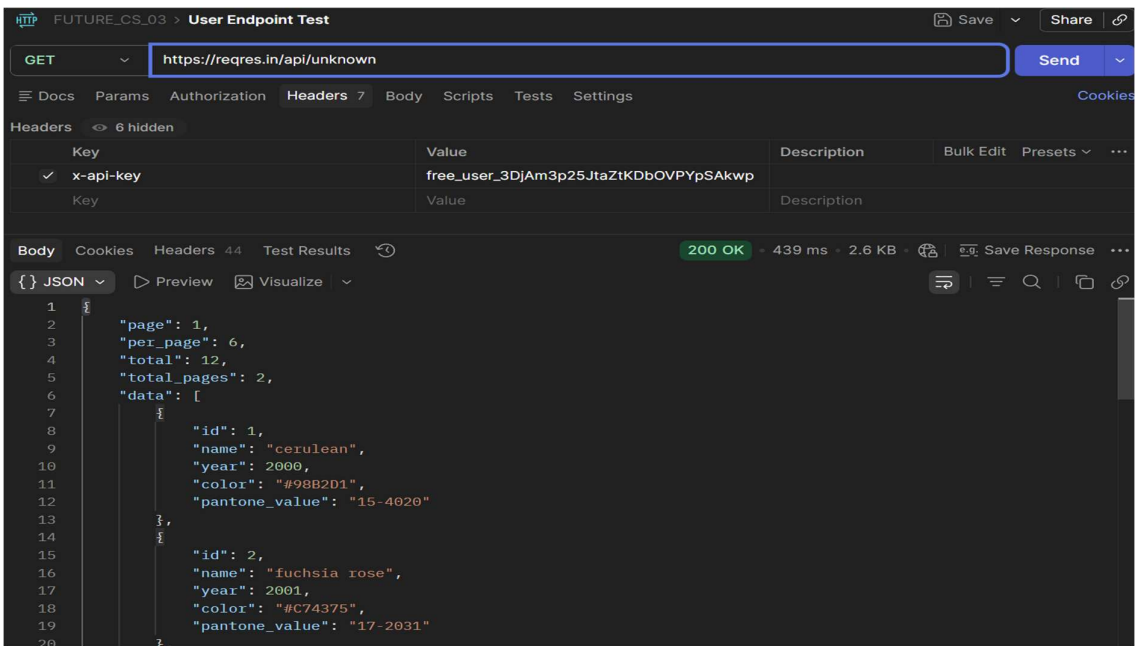
Informational

Business Impact

Public endpoint exposure is expected in API-driven applications. However, undocumented or unnecessary endpoints in production environments can increase the attack surface and create security risks.

Recommendation

Perform regular API inventory reviews, remove unused endpoints, and ensure endpoint documentation remains updated.



6. Risk Summary Table

Finding ID	Security Finding	Risk Level
F-01	Authentication Enforcement	Low
F-02	Authenticated Access Validation	Low
F-03	Object-Level Access Review	Informational
F-04	Error Handling Review	Low
F-05	Security Header Review	Low
F-06	Input Validation Review	Low

7. Final Security Assessment

The API demonstrated strong baseline security controls including authentication enforcement, secure error handling, input validation, rate limiting, and secure header implementation.

No critical or high-risk vulnerabilities were identified during this read-only assessment.

8. Analyst Conclusion

From an application security perspective, the target API demonstrates good security design practices expected in modern SaaS environments. Authentication, input validation, and error handling controls were implemented effectively.

Although no major vulnerabilities were identified, continued attention to authorization logic, security monitoring, and secure configuration management will help strengthen long-term API security posture.